

Министерство образования Республики Беларусь

Учреждение образования
**БЕЛОРУССКИЙ ГОСУДАРСТВЕННЫЙ УНИВЕРСИТЕТ
ИНФОРМАТИКИ И РАДИОЭЛЕКТРОНИКИ**

Факультет информационных технологий и управления
Кафедра интеллектуальных информационных технологий

ОТЧЕТ
по лабораторной работе №2
по дисциплине «Проектирование защищённых интеллектуальных
информационных систем»
на тему:

Анализ защищённости приложений.

Часть 1. Оценка защищённости разработанного приложения.

Анализ защищённости программных систем.

Часть 2. Оценка защищённости сторонних программных систем

Студенты гр. 321701

И. А. Политыко

В. А. Лукашов

Руководитель

Д. А. Сальников

Минск 2026

СОДЕРЖАНИЕ

Перечень условных обозначений	3
1 Постановка задачи	4
2 Часть 1. Оценка защищённости разработанного приложения . .	5
3 Часть 2. Оценка защищённости сторонних программных систем	9
Заключение	11
Список использованных источников	12

ПЕРЕЧЕНЬ УСЛОВНЫХ ОБОЗНАЧЕНИЙ

CSRF	— Cross-Site Request Forgery, Межсайтовая подделка запроса;
XSS	— Cross-Site Scripting, Межсайтовый скриптинг;
SQL	— Structured Query Language;
ORM	— Object-Relational Mapping;
TLS	— Transport Layer Security;
PBKDF2	— Password-Based Key Derivation Function 2;
Fernet	— Симметричная схема шифрования (AES + HMAC) из библиотеки cryptography;
СУБД	— Система управления базами данных;
CRUD	— Create, Read, Update, Delete;
MitM	— Man-in-the-Middle, Атака «человек посередине».

1 ПОСТАНОВКА ЗАДАЧИ

В части 1 необходимо разработать приложение, позволяющее добавить пользователя в систему, авторизовать его по идентификационным данным, создавать, редактировать, удалять и искать конфиденциальные и неконфиденциальные данные, а также деавторизовать пользователя. Далее выполнить анализ защищённости с позиций политики безопасности ОС, компонентов и их взаимодействия, сетевой политики и конфиденциальности данных.

В части 2 необходимо разработать методику оценки защищённости, применить её к приложению из части 1, предложить комплекс мер усовершенствования и рекомендации по безопасному использованию.

2 ЧАСТЬ 1. ОЦЕНКА ЗАЩИЩЁННОСТИ РАЗРАБОТАННОГО ПРИЛОЖЕНИЯ

Разработано веб-приложение **Secure Notes Lab** (каталог lab2/p1/app) на Python 3 / Flask с СУБД SQLite. Основные возможности:

- регистрация пользователя и вход по паролю;
- CRUD и поиск **заметок** (неконфиденциальные данные, хранятся открытым текстом);
- CRUD и поиск **секретов** (конфиденциальные данные, тело шифруется Fernet перед записью в БД);
- выход из сессии.

Запуск:

```
1 cd lab2/p1/app
2 python3 -m venv .venv && source .venv/bin/activate
3 pip install -r requirements.txt
4 python app.py
5 # http://127.0.0.1:5050
```

Листинг 2.1 — Запуск Secure Notes Lab

На рисунках 2.1–2.5 приведены снимки экрана интерфейса приложения.

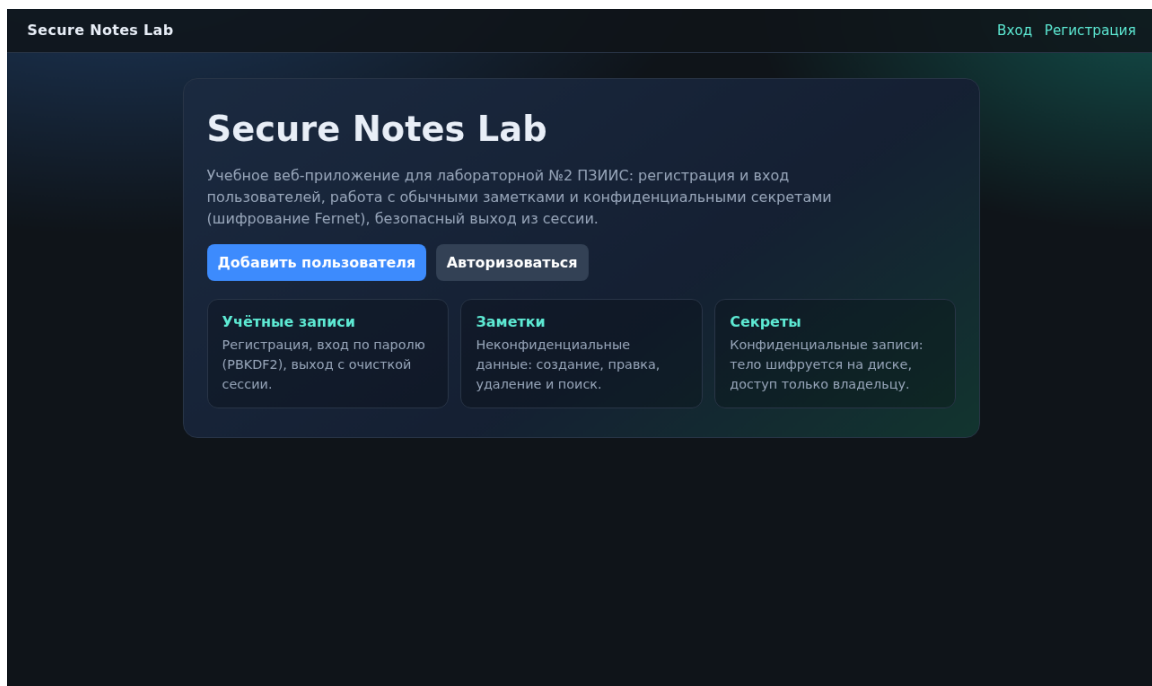


Рисунок 2.1 — Главная страница Secure Notes Lab

Анализ защищённости выполнен по четырём аспектам. Приложение запускается от непривилегированного пользователя и не требует прав **root**;

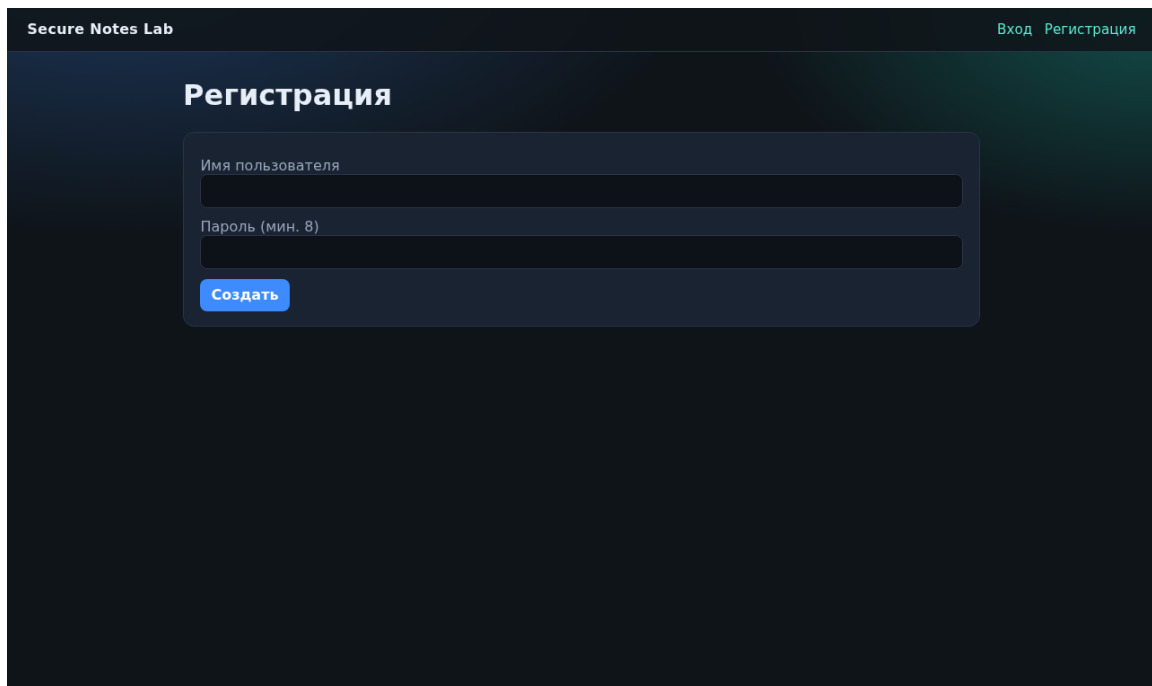


Рисунок 2.2— Форма регистрации пользователя

файлы БД и ключа шифрования размещаются в `instance/`. Риск: любой процесс того же пользователя ОС может прочитать `fernet.key` и расшифровать секреты. Меры: права доступа 600, отдельный системный пользователь, шифрование диска.

С точки зрения компонентов и взаимодействия: пароли хранятся как хэш PBKDF2-SHA256 (Werkzeug); изменяющие запросы защищены CSRF-токеном сессии; доступ к записям фильтруется по `user_id`; работа с БД через ORM снижает риск SQL-инъекций; шаблоны Jinja2 экранируют вывод по умолчанию. Ограничения: нет ограничения частоты попыток входа; единый ключ Fernet на всё приложение.

Сетевая политика: сервер по умолчанию слушает только 127.0.0.1; cookie сессии имеют флаги `HttpOnly` и `SameSite=Lax`; флаг `Secure` включается переменной окружения `LAB2_HTTPS=1`. Без TLS при публикации порта наружу возможен перехват сессии.

Тела секретов в SQLite хранятся как `ciphertext`; расшифрование выполняется только для владельца после авторизации. К конфиденциальным отнесены пароли учётных записей, содержимое секретов, ключ шифрования и идентификатор сессии; к неконфиденциальным — заголовки и тексты заметок владельца. Разделение реализовано разными сущностями (`Note / Secret`) и разным способом хранения. Ключ Fernet необходимо защищать на уровне ОС и не помещать в систему контроля версий.

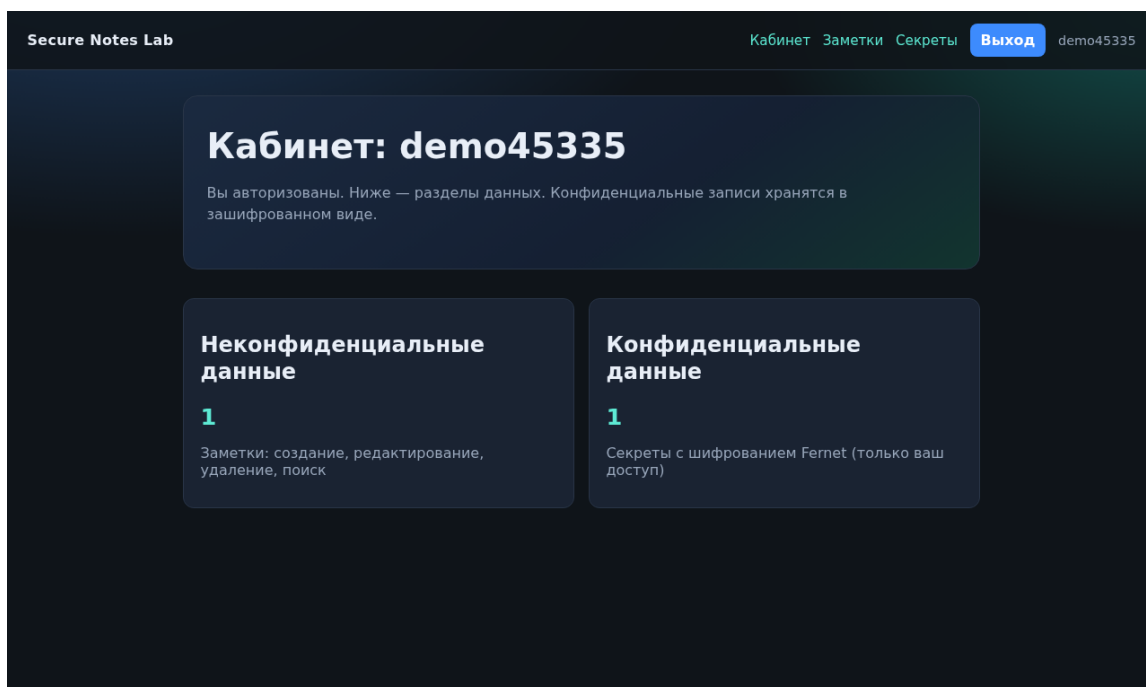


Рисунок 2.3— Кабинет авторизованного пользователя

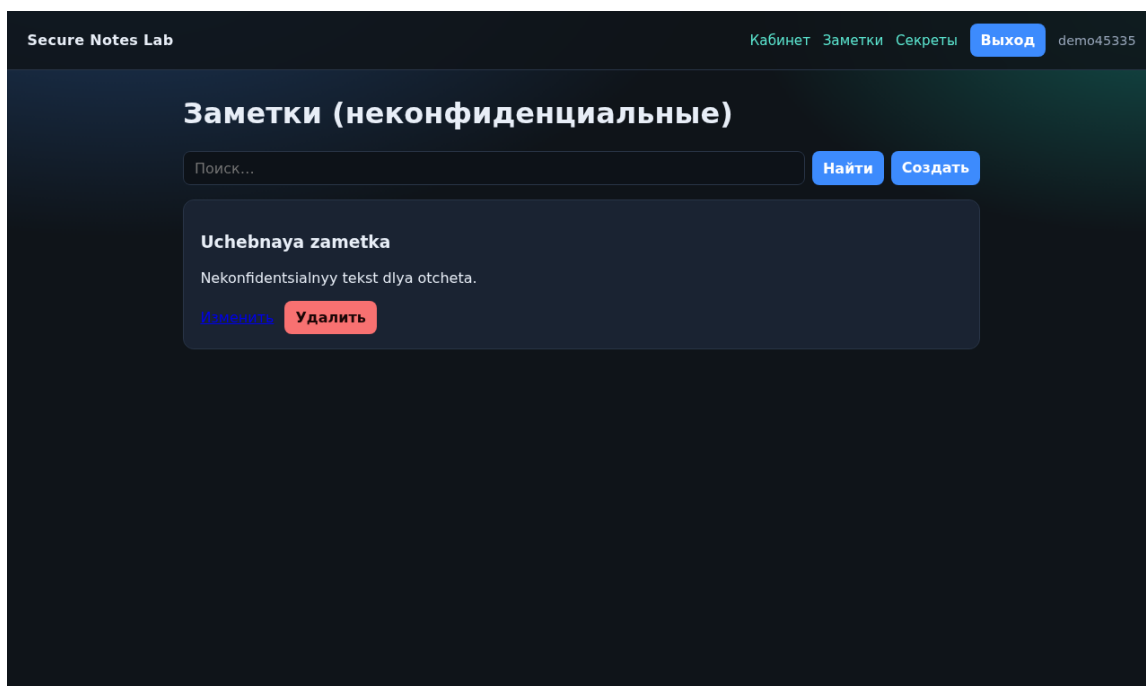


Рисунок 2.4— Список неконфиденциальных заметок

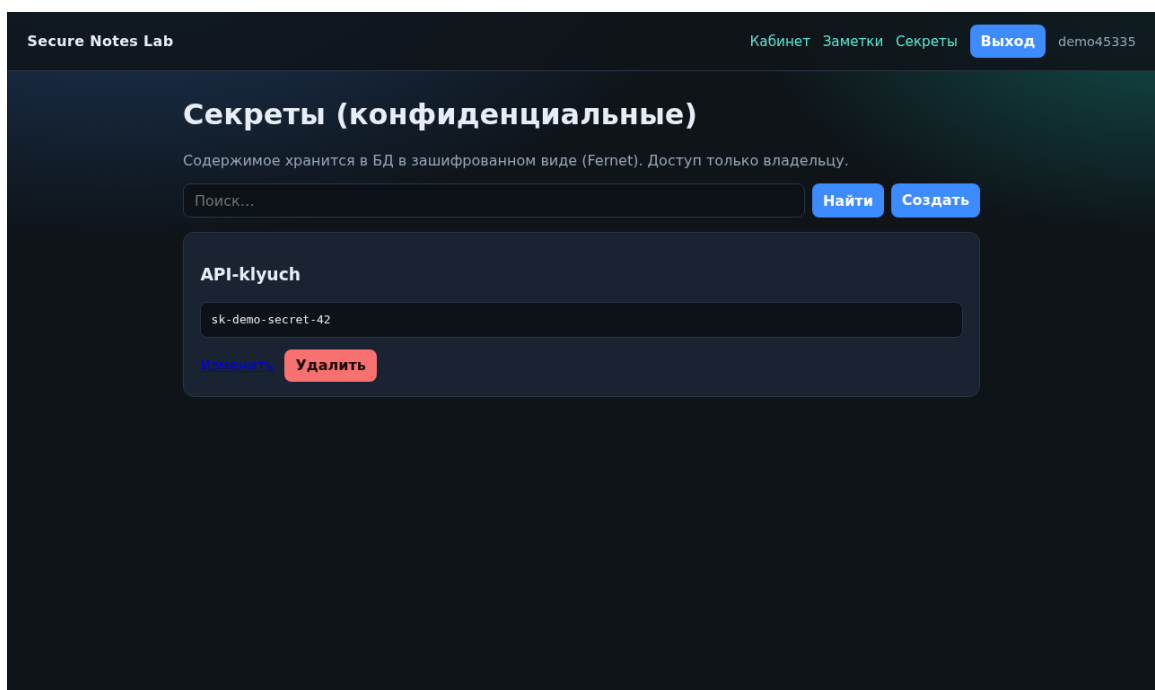


Рисунок 2.5— Конфиденциальные секреты (расшифровка только для владельца)

3 ЧАСТЬ 2. ОЦЕНКА ЗАЩИЩЁННОСТИ СТОРОННИХ ПРОГРАММНЫХ СИСТЕМ

В качестве объекта оценки выступает приложение Secure Notes Lab (результат части 1): Flask, SQLite, локальный HTTP на порту 5050, модули регистрации/авторизации, заметок и секретов.

Разработанная методика включает девять этапов:

- а) инвентаризация компонентов (ОС, runtime, СУБД, библиотеки, протоколы);
- б) построение модели угроз (активы, субъекты, типовые атаки);
- в) анализ ОС и окружения (права на файлы, пользователь процесса);
- г) анализ компонентов и взаимодействий (аутентификация, авторизация, CSRF, шифрование);
- д) анализ сетевой политики (интерфейс прослушивания, TLS, cookie);
- е) анализ конфиденциальности данных (классификация, at-rest encryption, изоляция);
- ж) анализ организационных мер (администрирование, бэкапы, ротация ключей);
- з) практическая проверка сценариев использования и негативных тестов;
- и) формирование выводов, мер улучшения и правил безопасного использования.

Уровни рисков: высокий / средний / низкий — по возможности эксплуатации и ущербу для конфиденциальности, целостности и доступности. Полный текст методики — файл `lab2/p2/methodology.md`.

Результаты применения методики согласуются с анализом части 1 и дополнительно фиксируют высокий риск при компрометации файлов `instance/` (ключ + БД), средний риск брутфорса пароля без rate limiting, средний риск MitM при выносе сервиса в сеть без TLS и низкий риск SQLi/XSS при текущей реализации (ORM + autoescape), при условии отключения экранирования.

Комплекс мер по усовершенствованию:

- а) вывод ключей шифрования из каталога данных; per-user DEK на базе KDF от пароля;
- б) ограничение частоты попыток входа и блокировка учётной записи;
- в) публикация только через reverse-проxy с TLS и Secure-cookie;
- г) журнал аудита обращений к секретам;
- д) заголовки безопасности (CSP, X-Content-Type-Options);
- е) регулярные обновления зависимостей и ротация секретов приложения.

Рекомендации по безопасному использованию:

- не публиковать порт 5050 в Интернет без прокси и TLS;

- не включать каталог **instance/** в публичные репозитории;
- использовать длинные уникальные пароли;
- запускать от отдельного непривилегированного пользователя ОС;
- после демонстрации удалять или ротировать учебные ключи и БД.

ЗАКЛЮЧЕНИЕ

В лабораторной работе №2 разработано приложение Secure Notes Lab с полным циклом работы с учётными записями, неконфиденциальными и конфиденциальными данными, выполнен анализ его защищённости и построена методика оценки, применённая к этой системе.

Семантическая составляющая. Показано, что защищённость определяется совокупностью мер на уровнях ОС, приложения, сети и данных; разделение конфиденциальных и неконфиденциальных сущностей и шифрование at-rest повышают устойчивость к атакам на хранилище, но не заменяют защиту ключей и канала.

Прагматическая составляющая. Получен воспроизводимый учебный стенд и формализованная методика, позволяющая повторять оценку, фиксировать риски по единым критериям и формулировать конкретные меры улучшения и правила эксплуатации.

СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ

- [1] Ховард М., Лебланк Д. Защищённый код. — М. : Русская редакция, 2004. — 704 с.
- [2] Ховард М., Лебланк Д., Вьегга Дж. 24 смертных греха компьютерной безопасности. — СПб. : Питер, 2010. — 400 с.
- [3] Панасенко С.П. Алгоритмы шифрования. Специальный справочник. — СПб. : БХВ-Петербург, 2009. — 576 с.
- [4] CWE: Common Weakness Enumeration [Электронный ресурс]. — Режим доступа: <http://cwe.mitre.org/>. — Дата доступа: 10.09.2026.
- [5] OWASP Vulnerability Scanning Tools [Электронный ресурс]. — Режим доступа: https://owasp.org/www-community/Vulnerability_Scanning_Tools. — Дата доступа: 10.09.2026.
- [6] Flask documentation [Электронный ресурс]. — Режим доступа: <https://flask.palletsprojects.com/>. — Дата доступа: 10.09.2026.